

TFC - mcl

1. Problema y usuario

MIDTECH S. A. enfrenta dificultades para realizar auditorías de cumplimiento normativo debido a la dispersión y actualización de sus políticas internas, lo que genera brechas de seguridad no detectadas. El asistente actuara bajo el rol de auditor de seguridad, permitiendo al responsable de sistemas contrastar en tiempo real si las políticas de la empresa cumplen con los requisitos normativos exigidos.

2. Tecnologías elegidas

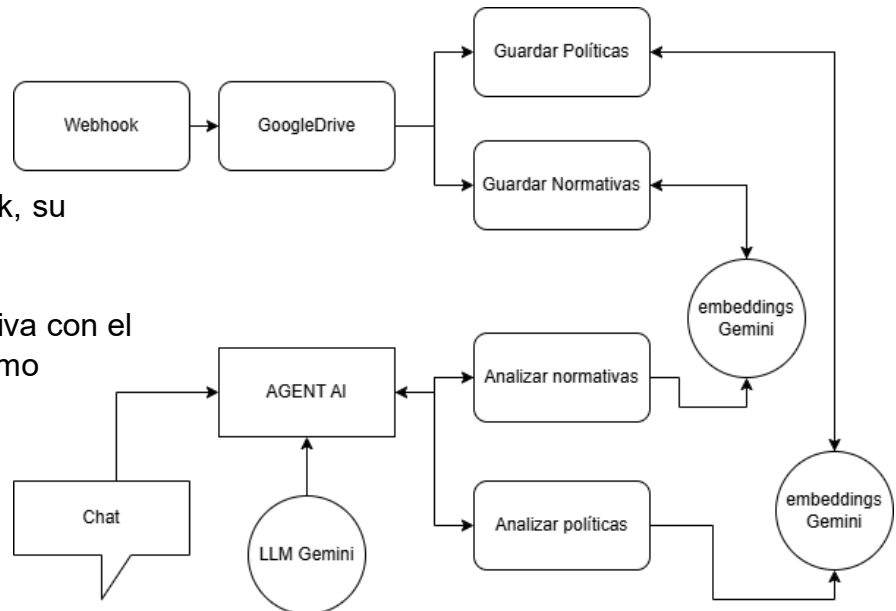
Componente	Tecnología	Razón de la elección
LLM	Gemini 2.5 Flash	Ofrece un equilibrio optimo entre razonamiento lógico complejo y baja latencia. Adicionalmente, su integración nativa con Google Drive agiliza drásticamente el flujo de datos para el RAG.
Orquestación	N8n	Permite la integración visual de APIs y la automatización mediante Webhooks.
Gestor Documental	Google Drive	Facilita la gestión colaborativa y la sincronización en la nube de las políticas y normativas.

3. Flujo de las 4 capacidades

- **Capacidad 1 (Análisis de políticas de seguridad):** Entrada de políticas desde Google Drive; proceso de carga mediante un Webhook en n8n; salida de contexto actualizado para el agente.
- **Capacidad 2 (Detección de riesgos e incumplimientos):** Entrada de la consulta del usuario; proceso de comparación semántica mediante LLM; salida de diagnóstico de brechas de cumplimiento.
- **Capacidad 3 (Respuesta a preguntas de auditoría):** Entrada de normativas externas (ENS); proceso de contraste con políticas internas; salida de recomendación de medidas correctivas.
- **Capacidad 4 (Propuestas de mejora):** Entrada de los resultados del Gap Análisis; proceso de síntesis y priorización mediante el LLM; salida de una lista concreta de recomendaciones de mejora para la política de MIDTECH.

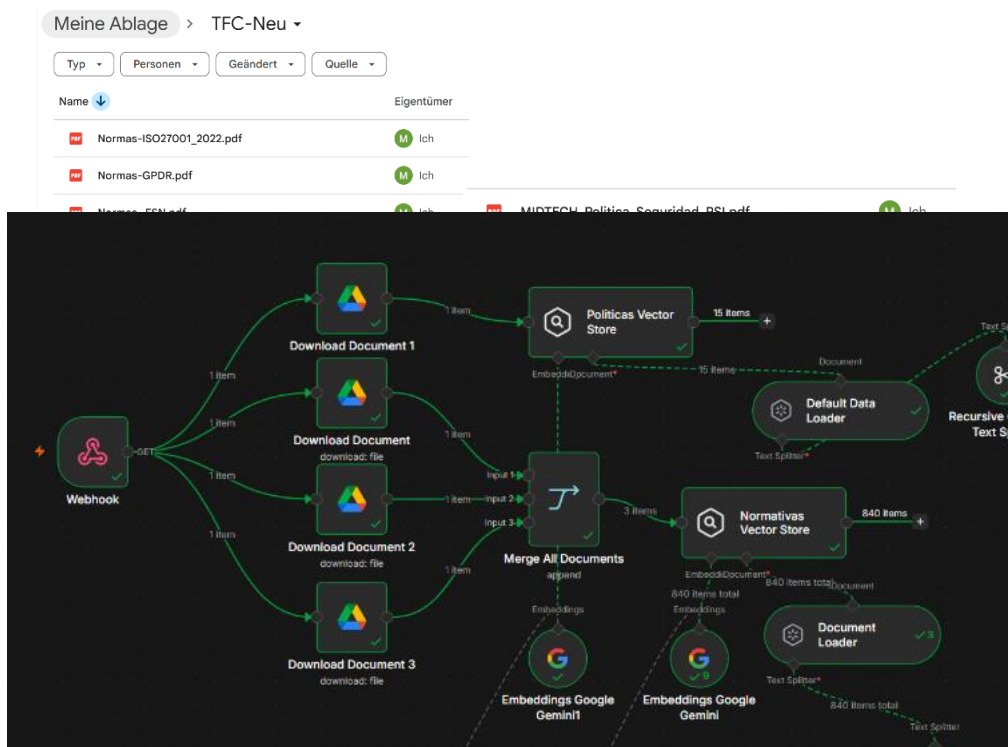
Este flujo permite pasar de la detección pasiva de riesgos a la intervención proactiva, transformando un simple análisis de cumplimiento en un plan de acción para el responsable de seguridad.

El diagrama ilustra el flujo de trabajo. Desde la ingesta de documentos vía Webhook, su vectorización mediante embeddings de Gemini, hasta la consulta interactiva con el AGENT AI, que actúa como motor de razonamiento para la auditoría de políticas y normativas.



Fase 2: Base de conocimiento

- **Fuente de datos:** Se han centralizado las políticas y normativas en un repositorio de Google Drive, permitiendo el versionado y la gestión colaborativa.
- **Proceso de Vectorización:** El sistema realiza la carga “Just-in-Time” disparada por Webhook, procesando los documentos mediante el modelo de embeddings de Gemini, garantizando que el asistente opere exclusivamente sobre la base de conocimiento proporcionada usando los siguientes documentos:
 - Marco normativo: ENS; GDPR e ISO27001.
 - Políticas internas: MIDTECH_Política_Seguridad_PSI.



La captura de pantalla detalla el proceso de ingesta y vectorización. Se observa el flujo automatizado iniciado mediante Webhook, que descarga de forma concurrente los documentos normativos y las políticas internas desde Google Drive. Posteriormente, se realiza una fusión y segmentación de los datos para su almacenamiento en los Vector Stores, utilizando el modelo de embeddings de Google Gemini para garantizar la precisión semántica durante las consultas de auditoría.

Fase 3: Descripción de las cuatro capacidades

En esta sección se detallan las capacidades funcionales del asistente de auditoría, validadas mediante la interacción directa con el sistema.

- **Capacidad 1: Ingesta y Análisis de Políticas de Seguridad**
 - El sistema realiza la carga y vectorización dinámica de las políticas de MIDTECH. Esto permite al asistente tener un contexto actualizado y preciso sobre las normas internas vigentes.
 - La captura de pantalla demuestra el conocimiento del Chat-bot que usara para responder.

¿Cumplimos con el artículo 32 del GDPR?

Según la Política de MIDTECH (sección 6.1 Cifrado en reposo), se cumple parcialmente con el requisito de cifrado al disponer de cifrado en reposo mediante AES-256 para las bases de datos de producción con datos clínicos y de investigación, y al cifrar los equipos portátiles con BitLocker.

Sin embargo, el Artículo 32 del GDPR (Seguridad del Tratamiento) exige la implementación de medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad apropiado al riesgo, incluyendo, entre otros, la seudonimización y el cifrado de datos personales.

Existen varias brechas significativas que indican un incumplimiento con este artículo:

- Cifrado en tránsito: Según la Política de MIDTECH (sección 6.2 Transferencia de información y Anexo A), "no existe una política documentada sobre el cifrado de la información en tránsito" y "no se especifican los protocolos mínimos aceptables (TLS 1.2 o superior)". Esto representa un incumplimiento directo del Artículo 32, ya que la información en tránsito es vulnerable y debe protegerse.
- Autenticación Multifactor (MFA): La Política de MIDTECH (Anexo A: Resumen de controles implementados, Política de contraseñas y sección 3.2) indica que la "Autenticación multifactor (MFA) No implementado" y se reconoce como una limitación ("Sin MFA. ... Su adopción está en evaluación para el próximo ejercicio presupuestario"). La MFA es una medida técnica clave para la seguridad de los accesos, y su ausencia generalizada es una debilidad en la protección de los datos personales.
- Gestión de incidentes de seguridad: La Política de MIDTECH (Anexo A: Resumen de controles implementados, Gestión de incidentes) menciona que la gestión de incidentes es "Parcial", con limitaciones como "Sin severidad. Sin plazo 72h GDPR. Sin CSIRT". El Artículo 32 del GDPR también requiere la capacidad de restaurar la disponibilidad y el acceso a los datos personales de manera oportuna en caso de un incidente físico o técnico, y un proceso para probar y evaluar regularmente la efectividad de las medidas de seguridad. La falta de un CSIRT formal y la ausencia de una gestión completa de incidentes con plazos definidos y severidad dificulta el cumplimiento de estos aspectos.

- **Capacidad 2: Detección de Riesgos e Incumplimientos**
 - Descripción: El agente ejecuta un Gap análisis automático, comparando el estado actual de las políticas frente a las mejores prácticas de seguridad, detectando brechas de cumplimiento de forma proactiva.
 - En la captura de pantalla se puede ver el Gap análisis de la pregunta del usuario.

¿Qué controles del Anexo A de ISO 27001 no estamos aplicando? dame un gap analysis

Aquí tiene un Gap Analysis de los controles del Anexo A de ISO 27001 que MIDTECH no está aplicando o aplica de forma insuficiente, basado en el "Anexo A: Resumen de controles implementados" de la Política de Seguridad de la Información de MIDTECH:

Gap Analysis

Riesgo/Incumplimiento	Referencia Política	Referencia Normativa (ISO/GDPR/ENS)	Gravedad
Control de acceso por mínimo privilegio sin revisión periódica formal	Control de acceso por mínimo privilegio (Anexo A)	ISO A.9.1.2	Media
Política de contraseñas con longitud mínima insuficiente y sin MFA	Política de contraseñas (Anexo A)	ISO A.9.4.3	Alta
Ausencia de Autenticación Multifactor (MFA)	Autenticación multifactor (MFA) (Anexo A)	ISO A.9.4.2	Alta
Cifrado en tránsito no documentado ni con protocolos mínimos	Cifrado en tránsito (Anexo A)	ISO A.10.1.1 / GDPR Art. 32	Alta
Seguridad física de sedes secundarias sin nivel equivalente al CPD Zaragoza	Seguridad física CPD Zaragoza (Anexo A)	ISO A.11.1	Media
Inventario de activos incompleto (sin SaaS de terceros ni clasificación de criticidad)	Inventario de activos (Anexo A)	ISO A.8.1	Media
Gestión de incidentes parcial (sin severidad, plazo 72h GDPR, ni CSIRT)	Gestión de incidentes (Anexo A)	ISO A.16.1 / GDPR Art. 33	Alta
Copias de seguridad sin copia offsite ni pruebas de restauración	Copias de seguridad (Anexo A)	ISO A.12.3	Alta
Ausencia de Plan de Continuidad (BCP/DRP) documentado	Plan de Continuidad (BCP/DRP) (Anexo A)	ISO A.17.1	Alta

- **Capacidad 3: Respuesta a Preguntas de Auditoría (Contrastación Normativa)**
 - Descripción: Esta capacidad permite contrastar las políticas internas con normativas externas (ENS, GDPR, ISO 27001). El agente está diseñado para citar explícitamente los apartados de la normativa que se están analizando, garantizando la trazabilidad.
 - La captura de pantalla demuestra que el agente cita los apartados de las normativas.

"¿Cómo se alinea nuestra política de cifrado con los requisitos del RGPD/GDPR? Cita el artículo correspondiente

Según la Política de MIDTECH (sección 6.1 Cifrado en reposo), se dispone de cifrado en reposo mediante AES-256 para las bases de datos de producción que contienen datos clínicos y de investigación, y los equipos portátiles están cifrados con BitLocker. Sin embargo, en la sección 6.2 (Transferencia de información) y en el Anexo A de la Política de MIDTECH, se identifica como una limitación que "no existe una política documentada sobre el cifrado de la información en tránsito" y "no se especifican los protocolos mínimos aceptables (TLS 1.2 o superior) para las" transferencias.

El control Artículo 32 del GDPR (Seguridad del Tratamiento) exige que el responsable y el encargado del tratamiento apliquen medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad adecuado al riesgo, incluyendo, entre otros, la seudonimización y el cifrado de datos personales. La falta de una política documentada y de especificación de protocolos mínimos para el cifrado en tránsito en MIDTECH representa una brecha frente a este requisito del GDPR, ya que el cifrado es una de las medidas mencionadas como adecuada para garantizar la seguridad de los datos personales.

- **Capacidad 4: Propuestas de Mejora**
 - Descripción: A partir de las brechas detectadas, el asistente sintetiza recomendaciones de mejora priorizadas, transformando el análisis pasivo en un plan de acción concreto para el responsable de sistemas.
 - La captura de pantalla demuestra que en preguntas de mejora, el agente se estructura en: Mejor propuesta, normativa que la justifica, prioridad y esfuerzo estimado.

Basado en los riesgos detectados en nuestra política de contraseñas, ¿qué tres medidas correctivas priorizadas deberíamos implementar?

A continuación, se presenta una lista priorizada de medidas correctivas basadas en los riesgos detectados en la política de contraseñas de MIDTECH:

Mejora Propuesta:

1. Acción concreta a realizar: Implementar la Autenticación Multifactor (MFA) de forma generalizada para todos los accesos a sistemas críticos y datos sensibles.
 - Justificación: Según la Política de MIDTECH (Anexo A: Resumen de controles implementados, Política de contraseñas y sección 3.2), la ausencia de MFA se reconoce como una limitación ("Sin MFA. ... Su adopción está en evaluación para el próximo ejercicio presupuestario."). El control Artículo 32 del GDPR (Seguridad del Tratamiento) exige la aplicación de medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad apropiado al riesgo, siendo la MFA una medida fundamental para la protección de la identidad y el acceso, minimizando el riesgo de accesos no autorizados.
 - Prioridad: Alta
 - Esfuerzo estimado: Alto
2. Acción concreta a realizar: Incrementar la longitud mínima requerida para las contraseñas a un mínimo de 12-14 caracteres, en lugar de los 8 actuales.
 - Justificación: La Política de MIDTECH (Anexo A: Resumen de controles implementados, Política de contraseñas) identifica que la "Longitud mínima de 8 chars insuficiente". Esta medida es crucial para aumentar la resistencia de las contraseñas a ataques de fuerza bruta y diccionarios, alineándose con las mejores prácticas de seguridad. Aunque no se ha encontrado un requisito específico en ENS para la longitud mínima, ISO 27001 (Control A.5.1.1 Política de control de acceso) exige la implementación de políticas de control de acceso que incluyan la gestión de contraseñas robustas.

Fase 4

Capacidad	1 - Análisis de políticas.
Herramienta / Modelo	Gemini 2.5 Flash

Texto del prompt de Sistema	CAPACIDAD 1: Análisis de políticas. Cuando se te pida analizar la política, genera un informe estructurado con: 1.Áreas Cubiertas: Temas detectados citando textualmente. 2.Nivel de cobertura: Evaluación (Alta/Media/Baja) según profundidad. 3.Áreas ausentes: Temas críticos de seguridad no tratados.Regla: Prohibido generalizar. Cada afirmación debe llevar una cita (ej: 'Sección 3.2').
Ejemplo de entrada	¿Cumplimos con el artículo 32 del GDPR?
Ejemplo de salida obtenida	Según la Política de MIDTECH (sección 6.1 Cifrado en reposo), se cumple parcialmente con el requisito de cifrado al disponer de cifrado en reposo mediante AES-256 para las bases de datos de producción con datos clínicos y de investigación, y al cifrar los equipos portátiles con BitLocker. Sin embargo, el Artículo 32 del GDPR (Seguridad del Tratamiento) exige la implementación de medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad apropiado al riesgo, incluyendo, entre otros, la seudonimización y el cifrado de datos personales. Existen varias brechas significativas que indican un incumplimiento con este artículo: • Cifrado en tránsito: Según la Política de MIDTECH (sección 6.2 Transferencia de información y Anexo A), "no existe una política documentada sobre el cifrado de la información en tránsito" y "no se especifican los protocolos mínimos aceptables (TLS 1.2 o superior)". Esto representa un incumplimiento directo del Artículo 32, ya que la información en tránsito es vulnerable y debe protegerse.
Valoración crítica	El modelo cumplió con la estructura requerida (Áreas cubiertas, nivel, ausentes) y realizó las citas correctamente, permitiendo identificar lagunas documentales.

Capacidad	2 - Detección de riesgos (Gap análisis).
Herramienta / Modelo	Gemini 2.5 Flash.
Objetivo del prompt	Identificar brechas de cumplimiento mediante un contraste técnico entre MIDTECH y la normativa (ENS/ISO/GDPR).
Texto del prompt de sistema	-CAPACIDAD 2: Detección de riesgos (Gap análisis)Ante una solicitud de análisis de incumplimiento, genera un Gap análisis en formato tabla: Riesgo/Incumplimiento Referencia Política Referencia Normativa (ISO/GDPR/ENS)Gravedad
Ejemplo de entrada	¿Qué controles del Anexo A de ISO 27001 no estamos aplicando? dame un gap análisis
Ejemplo de salida obtenida	Aquí tiene un Gap análisis de los controles del Anexo A de ISO 27001 que MIDTECH no está aplicando o aplica de forma insuficiente, basado en el "Anexo A: Resumen de controles implementados" de la Política de Seguridad de la Información de MIDTECH: Gap análisis

	Mirar captura de pantalla de capacidad 2 para formato de tabla
Valoración crítica	La salida en formato tabla es altamente efectiva para visualizar el riesgo y la referencia normativa, facilitando la priorización de auditorías.

Capacidad	3 - Auditoría conversacional.
Herramienta / Modelo	Gemini 2.5 Flash.
Objetivo del prompt	Realizar comparativas en tiempo real entre la política interna y normativas externas citando ambas fuentes.
Texto del prompt de sistema	-CAPACIDAD 3: Auditoría conversacional Ante consultas naturales, responde citando obligatoriamente ambas fuentes. Formato: 'Según la Política de MIDTECH (sección X), se hace [Y]. Sin embargo, el control [Z] de [Normativa] exige [W].'.Nota: Si no puedes citar ambos documentos, responde: 'Información insuficiente para un contraste normativo.'
Ejemplo de entrada	¿Cómo se alinea nuestra política de cifrado con los requisitos del RGPD/GDPR? Cita el artículo correspondiente
Ejemplo de salida obtenida	Según la Política de MIDTECH (sección 6.1 Cifrado en reposo), se dispone de cifrado en reposo mediante AES-256 para las bases de datos de producción que contienen datos clínicos y de investigación, y los equipos portátiles están cifrados con BitLocker. Sin embargo, en la sección 6.2 (Transferencia de información) y en el Anexo A de la Política de MIDTECH, se identifica como una limitación que "no existe una política documentada sobre el cifrado de la información en tránsito" y "no se especifican los protocolos mínimos aceptables (TLS 1.2 o superior) para las" transferencias. El control Artículo 32 del GDPR (Seguridad del Tratamiento) exige que el responsable y el encargado del tratamiento apliquen medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad adecuado al riesgo, incluyendo, entre otros, la seudonimización y el cifrado de datos personales. La falta de una política documentada y de especificación de protocolos mínimos para el cifrado en tránsito en MIDTECH representa una brecha frente a este requisito del GDPR, ya que el cifrado es una de las medidas mencionadas como adecuada para garantizar la seguridad de los datos personales.
Valoración crítica	El modelo aplicó la restricción de contraste obligatorio, devolviendo una respuesta rigurosa y fundamentada en secciones específicas de los documentos.

Capacidad	4 - Propuestas de mejora
Herramienta / Modelo	Gemini 2.5 Flash.
Objetivo del prompt	Generar planes de acción priorizados y justificados para mejorar el nivel de cumplimiento normativo.
Texto del prompt de sistema	-CAPACIDAD 4: 1.Propuestas de mejora. Ante una solicitud de mejora, genera una lista priorizada:Mejora Propuesta: 1.Acción concreta a realizar. 2.Justificación: Control normativo que la motiva. 3.Prioridad: (Alta/Media/Baja) basada en riesgo. 4.Esfuerzo estimado: (Bajo/Medio/Alto).
Ejemplo de entrada	Basado en los riesgos detectados en nuestra política de contraseñas, ¿qué tres medidas correctivas priorizadas deberíamos implementar?
Ejemplo de salida obtenida	A continuación, se presenta una lista priorizada de medidas correctivas basadas en los riesgos detectados en la política de contraseñas de MIDTECH: Mejora Propuesta: 1. Acción concreta a realizar: Implementar la Autenticación Multifactorial (MFA) de forma generalizada para todos los accesos a sistemas críticos y datos sensibles. - Justificación: Según la Política de MIDTECH (Anexo A: Resumen de controles implementados, Política de contraseñas y sección 3.2), la ausencia de MFA se reconoce como una limitación ("Sin MFA. ... Su adopción está en evaluación para el próximo ejercicio presupuestario."). El control Artículo 32 del GDPR (Seguridad del Tratamiento) exige la aplicación de medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad apropiado al riesgo, siendo la MFA una medida fundamental para la protección de la identidad y el acceso, minimizando el riesgo de accesos no autorizados. - Prioridad: Alta - Esfuerzo estimado: Alto
Valoración crítica	Las propuestas son concretas y el modelo justificó cada acción mediante el control normativo correspondiente, facilitando la hoja de ruta de implementación.

Ademes use un Prompt que tenga que usar para todas las capacidades:
Eres un auditor senior de ciberseguridad. Tu base de conocimientos está compuesta por la Política de MIDTECH, ISO 27001, GDPR y ENS. Tu comportamiento debe adaptarse según la intención del usuario siguiendo estas 4 capacidades estrictas:

....

-REGLAS GLOBALES: Nunca inventes información. Si no está en tus documentos (Knowledge Base), di que no lo sabes.

El tono debe ser profesional, técnico y orientado a la consultoría.

Si la pregunta no requiere una capacidad específica, responde de forma directa pero manteniendo siempre el rigor de las citas.

Si el usuario pregunta por la política de MIDTECH, es OBLIGATORIO usar la herramienta 'Políticas Vector Store'. Nunca asumas que no existe información sin antes haber consultado el tool de políticas

Fase 4.1 - **Conclusión**

La implementación de esta arquitectura RAG (Retrieval-Augmented Generation) basada en n8n y los modelos de lenguaje de Gemini ha demostrado ser una solución técnica viable y eficiente para automatizar el análisis de normativas de ciberseguridad. A través del desarrollo de las cuatro capacidades definidas, se ha validado que el sistema no solo interpreta correctamente las políticas internas de MIDTECH, sino que es capaz de realizar contrastes críticos con estándares internacionales como ISO 27001, GDPR y el ENS.

Asimismo, la integración de un *System Prompt* estructurado ha permitido reducir significativamente las alucinaciones del modelo, garantizando que cada respuesta esté fundamentada en citas textuales de los documentos fuente, lo cual es indispensable para cualquier labor de auditoría. Finalmente, el proyecto ha permitido identificar que la automatización de la gobernanza de datos mediante IA es una herramienta estratégica para reducir la carga operativa de los equipos de cumplimiento.

Propuestas de mejora:

- Migración del almacenamiento de documentos (actualmente en un flujo de ejecución de n8n) hacia una base de datos vectorial dedicada con persistencia permanente.
- Conectividad Ecosistémica: Conectar el agente con herramientas de gestión de tickets (como Jira o ServiceNow) o plataformas de correo para que las brechas detectadas se transformen automáticamente en tareas de remediación para el equipo de IT.

Webhook:

<https://mcl.d.app.n8n.cloud/webhook/569cdacf-3c59-4c7b-8ae1-2502f73553b4>

Chat:

<https://mcl.d.app.n8n.cloud/webhook/c3ba3f0a-f587-47c2-890d-04745a706629/chat>

Github:

[Ex-1237/TFC-mcl: Este es el trabajo TFC con la entrega de todos los documentos.](#)